FIAP ON

COLHEITA DE SOLUÇÕES INTELIGENTES - TRANSFORMANDO DADOS EM AÇÕES

ENGENHARIA SOCIAL: O PODER DA PERSUASÃO DIGITAL

8

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

LISTA DE FIGURAS

Figura 1 - *Phishing* como tática de engenharia social 8
Figura 2 - Exemplo de *Smishing* 9
Figura 3 - *Pharming* do *website* do Banco do Brasil 10
Figura 4 - Ilustração em 3D da COVID-19 (coronavírus) no microscópio 11
Figura 5 - Boleto malicioso se passando pela Registro.br 12
Figura 6 - Ticket de 1974 para transferência de ônibus em Los Angeles 13
Figura 7 - *Hacker* personificando um faxineiro para ter acesso físico às informações 14
Figura 8 - Coleta de informações 16
Figura 9 - O Spam original 19
Figura 10 - Caixa de e-mail na guia Spam 20
Figura 11 - Acesso a ambientes controlados 21
Figura 12 - Ex-ministra de Defesa alemã, Ursula von der Leyen, e hacker, Jan Krissler 23

FIAP

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

SUMÁRIO

1 ENGENHARIA SOCIAL: O PODER DA PERSUASÃO DIGITAL 4
1.1 Realizando teste de engenharia social 4
1.2 Componentes básicos dos ataques de engenharia social 5
1.3 Técnicas de motivação 6
1.4 Táticas de engenharia social 7
1.4.1 *Phishing* 7
1.4.2 Impersonation 12
1.4.3 Elicitation 15
1.4.4 *Hoaxes* 16
1.4.5 *Baiting* 17
1.4.6 URL Hijacking 18
1.4.7 Spam e Spim 19
1.4.8 *Shoulder surfing* 20
1.4.9 *Tailgating* e Piggybacking 21
2 O AVANÇO TECNOLÓGICO NOS GOLPES DIGITAIS 23
CONCLUSÃO 24
REFERÊNCIAS 25

FIAP

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

1 ENGENHARIA SOCIAL: O PODER DA PERSUASÃO DIGITAL

A proteção da informação é de vital importância para organizações e governos, e o desenvolvimento de medidas para combater o acesso ilegal à informação é uma área que recebe atenção crescente. As organizações e os governos têm interesse em proteger informações confidenciais e em garantir a confiança de clientes e cidadãos. A tecnologia, por si só, não é uma proteção suficiente contra o roubo de informações, pois os funcionários geralmente são o elo fraco de um sistema de segurança da informação, visto que podem ser influenciados a divulgar informações confidenciais, o que, posteriormente, permite que indivíduos não autorizados acessem sistemas protegidos.

A arte de influenciar as pessoas a divulgarem informações confidenciais é conhecida como “engenharia social” e o processo de fazê-lo é conhecido como “ataque de engenharia social”. Existem diversas definições de engenharia social e vários modelos de ataque. Mouton (2016) assim define engenharia social:

> Ciência do uso da interação social como um meio de convencer um indivíduo ou uma organização a cumprir uma solicitação específica de um invasor, na qual a interação social, a persuasão ou a solicitação envolvem uma entidade relacionada ao computador. (MOUTON *et al*., 2016).

1.1 Realizando teste de engenharia social

Se os testes de engenharia social e segurança física estiverem dentro do escopo de seu **teste de penetração** (*PenTest*), considere a possibilidade de não iniciar uma verificação imediata dos ativos de sua organização. Você pode iniciar com testes não técnicos, como a engenharia social e os próprios testes de segurança físicos, que podem ser usados para obter um reconhecimento adicional. Portanto, você poderá iniciar e testar as dimensões não técnicas de segurança da informação de uma organização para verificar os fatores em que ela está vulnerável.

Antes de começar a realizar testes técnicos, você pode executar os testes relacionados à engenharia social, baseado em pessoas em uma organização. A partir desse momento, você obterá essas informações para testar o elemento humano da organização.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

1.2 Componentes básicos dos ataques de engenharia social

Quando o assunto é engenharia social, precisamos primeiro entender alguns pontos que podemos a princípio chamar de básicos, mas que a complexidade pode ir escalando conforme a necessidade de se chegar no objetivo da informação.

O atacante precisa ser treinado na arte de persuadir o seu alvo, obviamente que quanto mais anos de experiência por parte do atacante, melhor e mais elaborado os golpes ficam, se apenas te ligarem no telefone dizendo que sua filha foi sequestrada você vai acreditar? Mesmo que você não tenha filha?

Pensando nisso, quanto mais informação prévia temos do alvo, mais fácil é de se montar uma história convincente para que a vítima faça o que está sendo solicitado a ela.

A maioria dos ataques de engenharia social compartilham alguns componentes básicos que lhes permitem ser bastante eficazes. Alguns desses componentes são:

- **Avaliação de alvos:** em muitos casos, os atacantes que têm alvos específicos em mente avaliam esses alvos e determinam como eles são suscetíveis a tipos também específicos de engenharia social. Eles avaliam seu nível geral de conhecimento em tecnologia da informação e segurança cibernética.
- **Pretexto:** os invasores se comunicam direta ou indiretamente por uma mentira, a fim de fazer com que alguém acredite em uma farsa. Essa crença pode estimular a vítima a confirmar uma ação que não pretendia ou que contraria seus interesses.
- **Manipulação psicológica:** os atacantes exploram a disposição dos seres humanos de depositar confiança nos outros e apoiam suas habilidades de tomada de decisão, às vezes, errôneas. Os invasores também exploram os preconceitos cognitivos inerentes a todas as pessoas para criar ataques mais eficazes e direcionados.
- **Construção de relacionamentos:** quanto mais confortável e amigável uma vítima estiver com o possível invasor, provavelmente haverá mais

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

confiança. Os atacantes poderão, portanto, tentar conhecer seu alvo em um nível pessoal.

- **Motivação:** os atacantes tentam motivar seu alvo a tomar alguma ação que acabe beneficiando o próprio atacante.

1.3 Técnicas de motivação

Para alcançar seu objetivo, um engenheiro social confia o sucesso de suas ações em uma ou mais técnicas de motivação diferentes.

- **Autoridade:** as pessoas tendem a obedecer às figuras com alguma autoridade, mesmo quando sabem que a ação solicitada é eticamente dúbia ou contrária aos seus próprios interesses, inclusive quando não têm informações suficientes para avaliar com precisão uma situação. Um atacante que se apresenta como figura de autoridade, como um policial, geralmente é mais bem-sucedido em seduzir a vítima a executar alguma ação que não deveria.
- **Escassez:** as pessoas tendem a atribuir valor indevido a objetos ou ideias incomuns ou difíceis de obter. Um item “secreto” ou “exclusivo” é mais autêntico para a vítima do que algo que ela encontra todos os dias. Por exemplo, o atacante pode reivindicar recompensar uma vítima com um item exclusivo que não pode ser adquirido em nenhum outro lugar.
- **Urgência:** semelhante à escassez, mas com um elemento de tempo envolvido. Um invasor pode incentivar a vítima a agir rapidamente para que não perca a oportunidade de adquirir algo. Por exemplo, uma “oferta por tempo limitado” terá mais chances de despertar o interesse da vítima.
- **Prova social:** isso é semelhante ao conceito de conformidade, no qual as pessoas tendem a refletir sobre as ações de outras pessoas porque desejam ser parecidas. Se uma vítima vê ou acredita que vê um atacante se engajando em algum comportamento, elas próprias podem se envolver nesse comportamento. Isso é mais eficaz se o comportamento for exibido por um grupo de pessoas em quem a vítima confia. Por exemplo, um grupo de atacantes trabalhando em conjunto pode instalar um programa antivírus

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

falso em seus computadores, e a vítima pode decidir fazer o mesmo para parecer competente para seus pares.

- **Semelhança:** é mais provável que as pessoas ouçam alguém e cumpram seus pedidos se sentirem alguma afinidade. As possíveis vítimas podem se enxergar ou ver afinidades nessa outra pessoa: ter um padrão de fala semelhante ou representar um ideal, como alguém fisicamente atraente. Os invasores podem aproveitar essa motivação para ser charmoso e persuasivo para pessoas específicas.
- **Medo:** como o medo é capaz de uma emoção tão intensa, ele pode motivar as pessoas a agirem de maneiras que normalmente não agiriam. O medo da perda é especialmente poderoso e os atacantes costumam usar táticas de medo para convencer a vítima de que ela pode perder algo muito importante.

Na literatura podemos encontrar diversas referências sobre persuasão e modos ao qual podemos aplicar no dia a dia, não para golpes, mas para um convívio melhor em ambientes corporativos, pode ser uma boa dica para o desenvolvimento pessoal e profissional, um excelente livro que fala sobre é "*Manual de persuasão do FBI*" escrito por Jack Schafer e Marvin Karlins.

1.4 Táticas de engenharia social

A seguir abordaremos algumas táticas que são associadas a engenharia social. Partiremos dos conceitos mais básicos e abrangentes como a "Pescaria" e, em seguida, vamos adentrar nos tipos mais elaborados de golpes que encontramos todos os dias no meio físico e digital.

1.4.1 *Phishing*

Em seu sentido original, *phishing* é a tática de engenharia social na qual um invasor tenta obter informações confidenciais de um usuário passando-se por uma figura confiável em comunicações via e-mail.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

Devido ao surgimento de outros meios de comunicação, além do e-mail, o termo "*phishing*" também pode abranger uma tentativa de obter informações confidenciais por meio de qualquer meio de comunicação eletrônica. O *phishing* é uma das táticas de engenharia social mais comum e eficaz porque é fácil de distribuir, impessoal e pode aproveitar truques técnicos, como falsificar os cabeçalhos FROM no e-mail para torná-lo mais convincente.

Figura 1 - *Phishing* como tática de engenharia social
Fonte: Shutterstock (2020)

Por exemplo, um invasor pode preparar um e-mail no qual alega trabalhar no banco em que a vítima tem conta. O conteúdo do e-mail informa à vítima que é preciso enviar sua senha para que sua conta possa ser redefinida corretamente e que, ainda, se a vítima não cumprir a tarefa dentro de uma semana, o banco encerrará sua conta. Isso alavanca as técnicas de motivação de urgência e medo. Quando a vítima recebe o e-mail, os cabeçalhos falsificados fazem parecer que ele realmente é proveniente do banco. A vítima, desaconselhada à ameaça, cumpre com a solicitação fraudulenta. Você sabia que várias ferramentas possuem recursos internos que facilitam o lançamento de uma campanha de *phishing*?

Por se tratar de uma das táticas de engenharia social mais comuns e eficazes, o *phishing* pode ser encontrado em termos relacionados a tipos específicos:

- ***Smishing*:** também chamado de *phishing* por SMS, é um ataque no qual o invasor atrai a vítima por meio de mensagens de texto SMS. A

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

predominância de *smartphones* pode tornar o uso do SMS mais atraente para um invasor do que o e-mail, mas é mais provável que as pessoas ignorem as mensagens de texto de remetentes desconhecidos ou não confiáveis do que com o e-mail. Variações de Smishing existem nos *instant messengers*, como WhatsApp ou Telegram, e tendem a ser mais bem-sucedidas quando a mensagem falsa parte de remetentes conhecidos, logo, o sequestro de WhatsApp, que geralmente também acontece por meio da engenharia social, é um passo preliminar quase obrigatório para o sucesso deste ataque.

Figura 2 - Exemplo de *Smishing*
Fonte: Demartini (2017)

- ***Vishing:*** também chamado de *phishing* de voz, é um ataque de *phishing* no qual um invasor atrai sua vítima por meio de um sistema telefônico tradicional ou de comunicações de voz baseadas em IP, como Voice over IP (VoIP). Embora seja difícil para um atacante falar com alguém diretamente a fim de atraí-lo, pode ser que essa abordagem seja mais eficaz, pois as pessoas tendem a confiar mais naqueles com quem podem conversar em tempo real.

- ***Pharming:*** nesse tipo de ação, o atacante leva a vítima a navegar para uma página da *web* maliciosa, que foi configurada para parecer oficial. O site pode imitar um site existente, como o site bancário da vítima, ou simplesmente apresentar um ar de legitimidade. A vítima interage com este site para fornecer suas informações confidenciais ao invasor, como preencher um formulário de login falso com sua senha.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

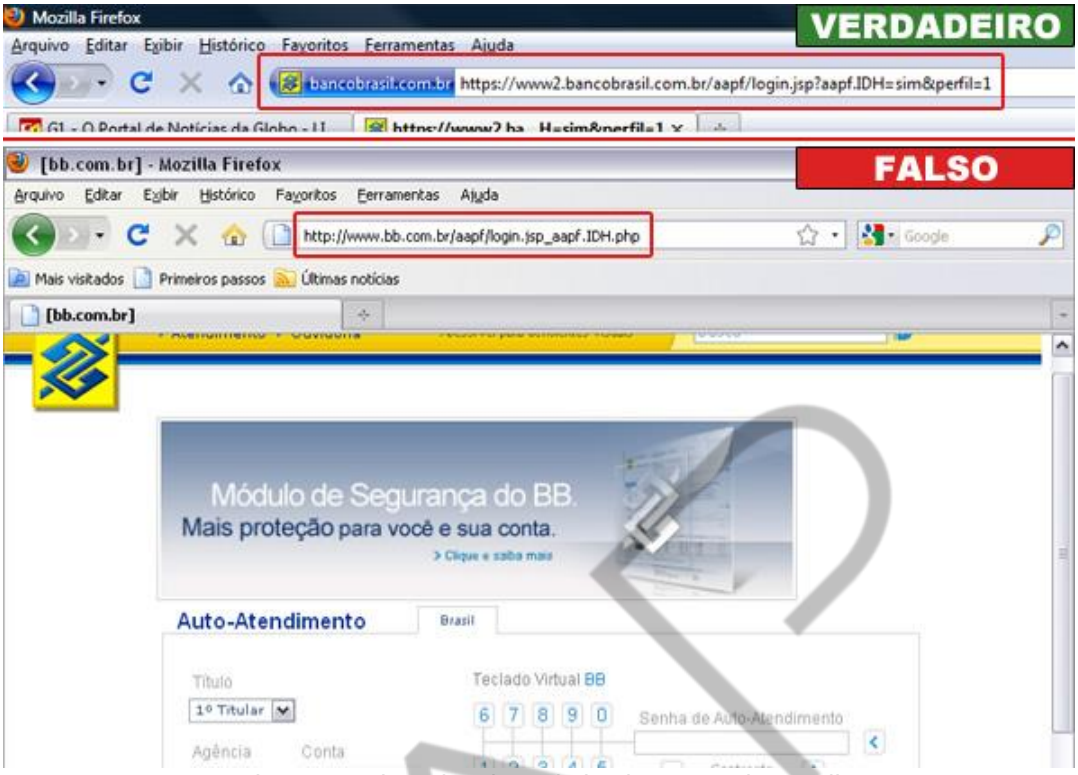


Figura 3 - *Pharming* do *website* do Banco do Brasil
Fonte: Rohr (2009)

Em geral é o passo seguinte do *smishing*, ou seja, a mensagem falsa em SMS ou por e-mail redireciona o usuário para o *website* da suposta empresa, totalmente clonado para que a vítima não note a diferença, assim, ela sente que está em um ambiente familiar e confortável. Um breve descuido e as credenciais estão na mão do criminoso.

No início de 2020, com o advento do coronavírus ou COVID-19, foram reportados vários casos de *phishing*, seja por e-mail, SMS e mensageiros instantâneos, atraindo visitantes para páginas que, com a promessa de informações ou até mesmo curas milagrosas do vírus, induziam seus visitantes a baixar e instalar *malwares* em seus equipamentos (Cyber Guru Enterprise, 2020; Rohr, 2020; Cluley, 2020), ou seja, os atacantes estavam nitidamente aproveitando o interesse geral de todos para atacar. Estima-se que 3% dos e-mails que chegaram nas caixas postais em março de 2020 sobre o vírus eram maliciosos; e outros 5% foram considerados suspeitos (Rohr, 2020).

Para evitar ser uma destas vítimas, além de um antivírus instalado e atualizado no computador e *smartphone*, é necessário se informar em fontes confiáveis que, no caso da COVID-19, é a Agência Nacional da Saúde (ANS) e a Organização Mundial

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

da Saúde (OMS). Trata-se do melhor antídoto, não só contra os *malwares*, mas também contra as *fakes news* (Cluley, 2020).

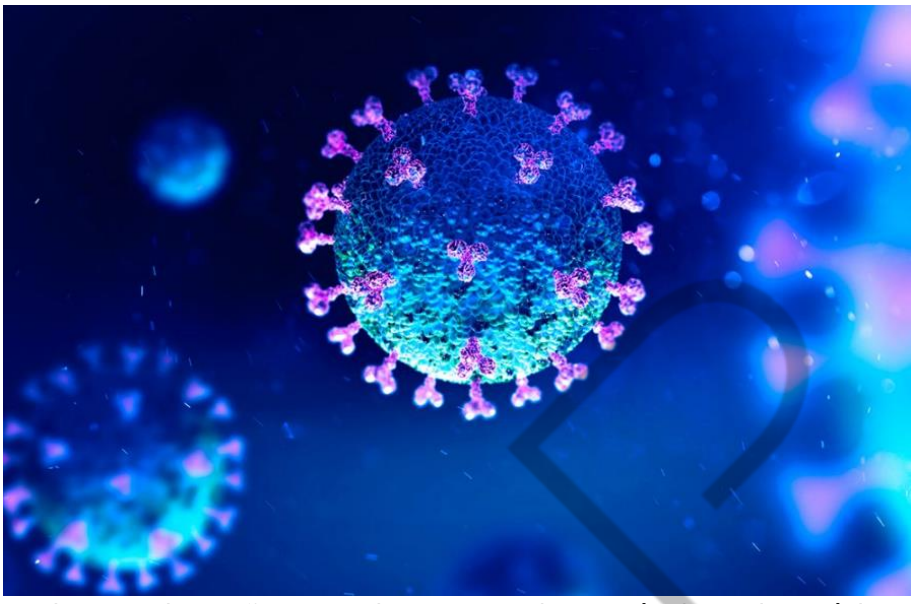


Figura 4 - Ilustração em 3D da COVID-19 (coronavírus) no microscópio
Fonte: Shutterstock (2020)

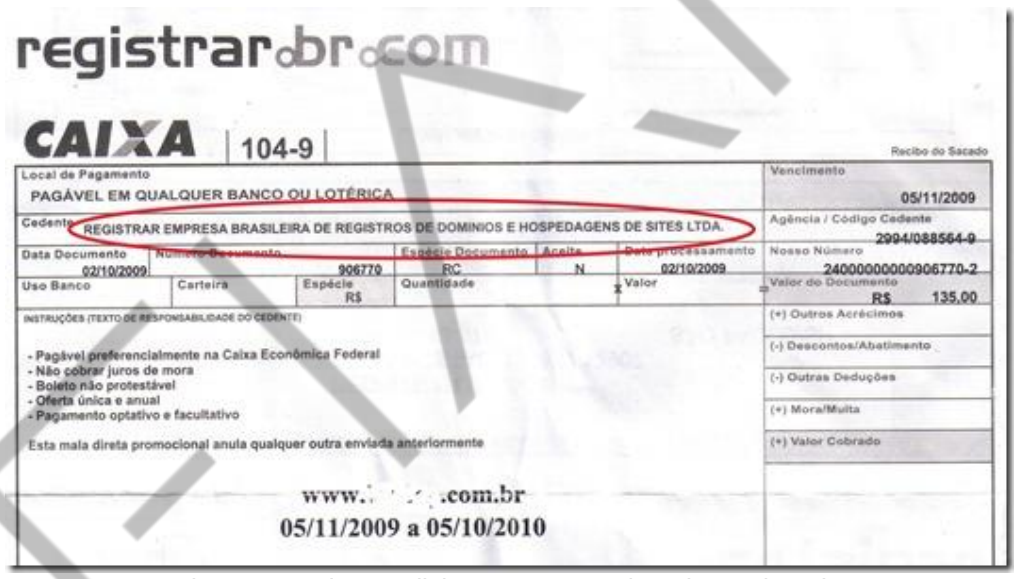
- ***Spear phishing*:** trata-se de um ataque de *phishing*, independentemente do meio, criado para atingir pessoas ou grupos específicos. Os ataques de *spear phishing* exigem que o invasor realize algum reconhecimento e colete algumas informações baseadas em seus alvos antes de iniciar o ataque. O invasor usa o que aprendeu sobre os hábitos, os interesses e as responsabilidades do trabalho de seus alvos para criar uma mensagem personalizada muito mais convincente do que uma mensagem genérica enviada a todos. Por exemplo, um invasor pode saber que o aniversário de um alvo será em breve e que planeja realizar uma festa em um local específico. O atacante pode fingir que trabalha para esse local e mencionar a festa de aniversário do alvo.

- ***Whaling*:** essa é uma forma de *spear phishing* cujo foco são indivíduos particularmente ricos ou poderosos, como CEOs de empresas, da *Fortune 500*. O risco é maior para um invasor, pois esses indivíduos provavelmente estarão mais protegidos do que uma pessoa comum. No entanto, o pagamento do atacante será significativamente maior. Por exemplo, uma fatura falsa e urgente pode induzir um CEO a pedir ao departamento

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

financeiro que transfira um pagamento “muito atrasado” para a conta do atacante.

- **Boleto falso:** um golpe tipicamente brasileiro pode ser classificado como um tipo de *phishing*, o fenômeno dos boletos falsos, que são gerados indevidamente por uma empresa se passando pela outra. Uma das maiores vítimas são os clientes da REGISTRO.BR (s.d.), criado pela Fapesp para os registros dos domínios “.br” no Brasil. Disponibilizando (no passado) todos os dados de cobrança de um determinado domínio abertamente na Internet, possibilitaram a terceiros criar boletos de cobrança convincentes. Os golpistas mais espertos (e menos gananciosos) emitiam uma cobrança com o mesmo valor cobrado anualmente pela Registro.br, tornando o golpe ainda mais eficiente.


registrar.br.com

CAIXA | 104-9 |

Recibo do Sacado

Local de Pagamento: PAGÁVEL EM QUALQUER BANCO OU LOTÉRICA

Vencimento: 05/11/2009

Cedente: REGISTRAR EMPRESA BRASILEIRA DE REGISTROS DE DOMINIOS E HOSPEDAGENS DE SITES LTDA.

Agência / Código Cedente: 2994/088564-9

Data Documento: 02/10/2009 | Número Documento: 906770 | Espécie Documento: RC | Aceite: N | Data processamento: 02/10/2009

Nosso Número: 24000000000906770-2

Uso Banco | Carteira | Espécie: R$ | Quantidade | x Valor | = Valor do Documento: R$ 135,00

INSTRUÇÕES (TEXTO DE RESPONSABILIDADE DO CEDENTE)

- Pagável preferencialmente na Caixa Econômica Federal
- Não cobrar juros de mora
- Boleto não protestável
- Oferta única e anual
- Pagamento optativo e facultativo

Esta mala direta promocional anula qualquer outra enviada anteriormente

(+) Outros Acréscimos
(-) Descontos/Abatimento
(-) Outras Deduções
(+) Mora/Multa
(+) Valor Cobrado

www.[illegible].com.br

05/11/2009 a 05/10/2010

Figura 5 - Boleto malicioso se passando pela Registro.br
Fonte: EVENTOSBH (2009)

1.4.2 Impersonation

Impersonation, na língua portuguesa, significa representação, que é o ato de fingir ser alguém que você não é. Muitos dos ataques de engenharia social mais eficazes, especialmente o *phishing*, geralmente incluem a *impersonation* como componente.

Nesse contexto, fingir ser alguém é um elemento de um ataque, e não um ataque propriamente dito, pois geralmente depende de situações em que um alvo não

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

pode confirmar suficientemente a identidade do criminoso. Um exemplo comum é quando um invasor finge ser um funcionário do suporte técnico e liga para outro funcionário, solicitando sua senha para que ele possa redefinir um banco de dados de contas. Se a pessoa que recebeu a ligação não estiver familiarizada com os funcionários do suporte técnico ou com o número de telefone que eles usam, ela pode não suspeitar da solicitação.

Um dos grandes expoentes da **engenharia social por representação** é o *hacker* Kevin Mitnick, que embora fosse tecnicamente muito qualificado e capaz, confessa em seu livro, "*A arte de enganar*" (2006), que na maioria das vezes suas invasões eram fruto da mais pura engenharia social.

Para ilustrar suas capacidades, Greene (2003) e Mitnick & Simon (2006) contam que Mitnick, aos 12 anos de idade, reparou que todo o sistema de transferência de ônibus da cidade de Los Angeles da época dependia de tickets em papel, perfurados pelos motoristas em um padrão determinado. Pela observação e perguntas aparentemente despretensiosas a um motorista de ônibus com o qual fez amizade (situação mais bem enquadrada na técnica seguinte, a elicitação), Mitnick descobriu como adquirir o furador especial, teve acesso às informações que precisava e obteve os tais recibos por meio de uma técnica chamada de *dumpster diving*: ele **revirou as latas de lixo** ao lado da garagem de ônibus, descobrindo que os motoristas jogavam talões e tickets parcialmente preenchidos fora.

Figura 6 - Ticket de 1974 para transferência de ônibus em Los Angeles
Fonte: Chesi (2012)

A propósito, muita informação pode ser descoberta sobre um alvo revirando o lixo dele. Tome cuidado com as etiquetas de compras internacionais, pois elas contém informações valiosas de contato a seu respeito. Uma sugestão é você sobrepor seus dados com canetinha preta de tinta espessa que impede a leitura de seus dados pessoais, mesmo contra a luz.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

Dumpster diving pode ser um passo preliminar ao *spear phishing*, que depende de informações do alvo para realizar um *phishing* mais personalizado e, assim, supostamente mais confiável.

Tsutomu Shimomura, um especialista em segurança da informação que ajudou o FBI na década de 1990 a capturar Kevin Mitnick, escreveu um livro com John Markoff denominado "*Contra-ataque*" (1996), em que a dupla relata a perseguição ao famoso hacker. O livro virou filme nos anos 2000, que foi chamado de "*Caçada Virtual*". Em vários trechos é retratado Mitnick realizando a **engenharia social por representação**, passando-se, por exemplo, por funcionário terceirizado de manutenção e tendo acesso físico a empresas que precisava *hackear*, ganhar vantagens e continuar fugindo.

Figura 7 - *Hacker* personificando um faxineiro para ter acesso físico às informações
Fonte: Shutterstock (2020)

O uso do *impersonation* costuma ser mais eficaz em interações face a face com a vítima, isso porque a maioria das pessoas evita ser rude quando está falando diretamente com outra. Portanto, elas talvez tenham menos probabilidade de questionar o impostor do que se tivessem sido abordadas por e-mail ou telefone. Obviamente, esse contato presencial só funcionará se o alvo (possível vítima) não souber como essa pessoa realmente é ou se não a conhecer bem o suficiente para suspeitar de sua aparência.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

1.4.3 Elicitation

Em português significa “elicitação”. É o processo de coleta ou aquisição de dados de seres humanos. É diferente das informações coletadas sobre os seres humanos. No processo de obtenção de informações, um engenheiro social tentará aprender ou acessar informações úteis entrando em contato com pessoas que possam fornecer certas informações importantes. A abordagem é utilizada quando o atacante precisa de informações que só serão adquiridas por meio de outras pessoas. Como *Impersonation*, a *Elicitation* não é um ataque de engenharia social em si, mas uma abordagem que pode ser utilizada como parte de um ataque real.

Algumas técnicas específicas de *elicitation* incluem:

- **Solicitações:** o engenheiro social em uma posição confiável solicita que a potencial vítima forneça algumas informações úteis. Esse é o método mais direto do que *elicitation*.
- **Interrogatório:** um engenheiro social faz perguntas diretamente às pessoas com a intenção de extrair informações úteis. Ele pode estar se passando por uma figura que tenha autoridade a fim de melhorar suas chances de obter respostas.
- **Pesquisas:** um engenheiro social coleta indiretamente dados de voluntários. As pesquisas são eficazes quando o interrogatório não é uma opção viável.
- **Observação:** um engenheiro social examina o comportamento do alvo, em um ambiente específico, sem o conhecimento deles. O comportamento de uma pessoa e a rotina diária podem fornecer ao engenheiro social uma visão de como ela pensa ou age em determinadas situações. Lembre-se do exemplo de Kevin Mitnick estudando o motorista do ônibus, relatado na seção anterior.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

Figura 8 - Coleta de informações
Fonte: Shutterstock (2020)

A *elicitation* é útil no suporte a uma variante do *phishing* conhecida como *Business Email Compromise* (BEC − Comprometimento de E-mail Comercial, em português), em que um invasor geralmente se passa por um executivo de alto nível ou sequestra diretamente a conta de e-mail. Em seguida, ele envia um e-mail para o departamento financeiro, solicitando dinheiro por meio de um método como transferência. Como o pessoal do financeiro acredita que a solicitação é legítima, aprovará a transferência e, por consequência, o invasor obtém esse pagamento com sucesso sem roubá-lo diretamente.

1.4.4 *Hoaxes*

Hoaxes é outro elemento da engenharia social em que o atacante apresenta uma situação fictícia como real. Está relacionado à ideia de uma farsa, embora, em uma farsa, o objetivo do atacante não seja necessariamente o ganho financeiro. Observe, a seguir, alguns exemplos de farsas, também conhecidos como “trotes” que podem convencer usuários inocentes:

- Um *pop-up* informando que um programa antivírus identificou a presença de malware no sistema da possível vítima e que ela deve clicar em um *link*

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

para corrigir essa infecção. Na realidade, o próprio *link* leva ao código malicioso.

- Uma mensagem de e-mail em que se afirma ser de um cidadão de um país estrangeiro, na qual pede ao alvo que os ajude a acessar fundos em uma conta bancária. Eles solicitam que a possível vítima envie dinheiro antecipadamente e que receberá uma porcentagem da soma total da conta. Na realidade, isso não existe e o criminoso simplesmente pega o dinheiro que a vítima enviou e desaparece.
- Um e-mail que afirma ser de uma empresa muito conhecida com uma mensagem que informa que a conta do alvo foi sinalizada por atividade suspeita. A vítima deve entrar no site da empresa e confirmar que a conta não foi comprometida. Na realidade, o *link* de entrada é direcionado a um site *pharming,* que rouba as credenciais do usuário.
- Uma postagem no blog alegando que a maioria dos problemas de desempenho do computador é o resultado da RAM que não foi “limpa” com uma certa frequência. A publicação oferece etapas sobre como executar uma operação de “limpeza” na linha de comando. Na realidade, esse comando formatou a unidade de armazenamento de um usuário, limpando completamente seu conteúdo.

1.4.5 *Baiting*

Significa “isca”, que é a ação na qual um atacante de engenharia social deixa algum tipo de mídia física em um determinado lugar para que uma pessoa aleatória a encontre e a conecte ao seu computador pessoal ou corporativo. Isso explora a tendência das pessoas se interessarem por objetos e situações fora do comum ou que chamam a atenção de alguma maneira. A forma mais comum de *baiting* envolve deixar um *pen drive* USB em um estacionamento ou em outra área pública perto de um espaço de trabalho.

Um funcionário pode perceber a unidade USB no chão, pegá-la e conectá-la ao computador. Sem o conhecimento do usuário, a unidade foi pré-carregada com *software* malicioso que compromete o computador do funcionário. Esses tipos de

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

ataques podem depender do computador da vítima ter a execução automática ativada para que o código malicioso seja executado imediatamente. O *malware*, dependendo de sua natureza, pode se espalhar e começar a infectar outros *hosts* na rede.

Mesmo que a execução automática não esteja ativada, o ataque ainda pode atrair um usuário para executar o código malicioso na unidade USB, disfarçando-o com algo divertido, como um jogo, um programa antivírus ou arquivos com nomes enigmáticos e curiosos. E-mails mandados anos atrás com dizeres “sua mulher está te traindo, clique aqui para ver as fotos” são um exemplo clássico de *baiting* que apela para a emoção e curiosidade humana, fazendo, assim, muitas vítimas.

Pode parecer cena de filme do James Bond, mas é real, uma operação montada pela CIA em conjunto com Israel se utilizou de um vírus de computador criado por eles mesmos, denominado “Stuxnet”, que tinha como objetivo infectar centrífugas de enriquecimento de urânio no Irã, o principal problema, por se tratar de um ambiente controlado militarmente, era como entregar esse vírus aos computadores da usina.

Em 2010 foi descoberto que a técnica de *baiting* foi utilizada no Irã. *Pendrives* infectados com o vírus foram colocados no estacionamento da usina por agentes secretos estadunidenses em parceria com os israelenses. Posteriormente achados por funcionários, esses *pendrives* foram inseridos nos computadores do Irã e o vírus se espalhou, afetando a produção e não enriquecendo de urânio, atrasando assim, o desenvolvimento nuclear em quase uma década. Uma missão bem-sucedida por parte da CIA e seus agentes.

1.4.6 URL Hijacking

O sequestro de URL (*URL Hijacking*), também conhecido como *typosquatting*, é um ataque de engenharia social que explora os erros de digitação que os usuários podem cometer ao tentar navegar em um site. Por exemplo, um usuário que deseja visitar o site da FIAP pode digitar em seu navegador: fiapi.com.br.

O navegador não tem como saber que isso foi um erro, por isso envia a solicitação do usuário ao site. Caso um invasor já tenha registrado, previamente, esse domínio e está contando com os usuários desatentos para cometerem erros desse

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

tipo. Portanto, o usuário é basicamente direcionado para um site malicioso, e não para o destino pretendido.

O site malicioso pode ser claramente o errado, mas atacantes mais inteligentes transformam o site falso em um site que imita de perto o site real (tornando-se um *pharming*, comentado anteriormente). Dessa forma, a vítima talvez nunca saiba que cometeu um erro e continuará ignorando o problema. Além dos erros de ortografia, o sequestro de URL também abrange casos em que o domínio de nível superior errado é usado, por exemplo fiap.gov.

Observe que muitas empresas investem um esforço significativo no combate a domínios com erros de digitação (muitas vezes adquirindo os domínios com variações e redirecionando para o site certo), mas sempre haverá situações a serem exploradas.

1.4.7 Spam e Spim

O Spam é um ataque no qual a caixa de entrada do usuário é inundada com mensagens de anúncios, promoções, esquemas de enriquecimento rápido e outras mensagens não solicitadas. Como o *phishing*, o termo inicialmente incluía mensagens baseadas em e-mail, mas agora pode incluir qualquer meio de comunicação. Uma curiosidade em relação à origem do termo, ele foi inspirado em um esquete do grupo de humor britânico **Monty Python**, repetindo o termo dezenas de vezes das formas mais inconvenientes possíveis. O grupo caçoava de uma marca real de uma espécie de presunto enlatado.

Figura 9 - O Spam original
Fonte: Shutterstock (2020)

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

O spam geralmente é utilizado em conjunto com o *phishing*, isso porque o invasor tenta sobrecarregar o maior número possível de alvos com mensagens não solicitadas, esperando que pelo menos alguns usuários atuem neles.

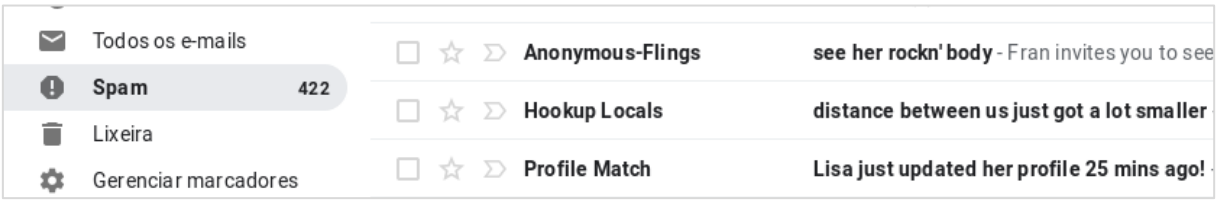


Figura 10 - Caixa de e-mail na guia Spam
Fonte: Elaborado por Cleiton Alves (2020)

Além do e-mail, o *spam* também pode ser transmitido por mensagens instantâneas. Por exemplo, um invasor pode enviar mensagens não solicitadas a membros de um grupo do Facebook prometendo muitas vantagens em um determinado produto se eles seguirem um link. Isso, às vezes, é chamado de *spim*.

O *Spim* pode ser mais difícil de executar, visto que é necessário uma interação síncrona. Se a vítima espera interagir com uma pessoa em tempo real, ela pode ficar mais desconfiada se o atacante não responder como um humano, ou seja, acredita que o remetente é um *bot*.

Ainda assim, sabe-se que o *spim* funciona, especialmente quando o alvo não é especialista em tecnologia. Devido ao surgimento de filtros robustos em clientes de e-mail e mensagens instantâneas, *spam* e *spim* são menos eficazes do que costumavam ser. No entanto, o volume de mensagens não solicitadas é tão grande que, todos os dias, um usuário suspeito é capturado com sucesso por *spam* ou *spim*.

1.4.8 *Shoulder surfing*

Shoulder surfing é um ataque de engenharia social em que o atacante observa o comportamento de um alvo sem que seja notado. A possível vítima normalmente está no computador ou em outro dispositivo e pode estar trabalhando com informações confidenciais ou inserindo suas credenciais em um sistema de autenticação.

O atacante, que está atrás do alvo, é capaz de ver o que está na tela ou quais teclas o alvo está pressionando. O *shoulder surfing* não precisa ser literalmente

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

alguém espiando por cima do ombro do outro. O atacante pode fazer a mesma coisa usando a câmera de um smartphone para capturar fotos ou vídeos com antecedência, com a vantagem adicional de poder voltar a essa gravação mais tarde, em vez de confiar apenas na memória. O invasor nem precisa estar fisicamente presente durante o ataque, ele pode colocar a câmera em uma mesa próxima, pressionar gravar e sair. Mais tarde, retorna para descobrir imagens do alvo trabalhando no computador.

Vamos acompanhar um golpe um pouco mais elaborado na sequência que usa de técnicas parecidas para se obter informações confidenciais do alvo escolhido a distância.

1.4.9 *Tailgating* e Piggybacking

Tailgating é um ataque em que o atacante acessa uma área segura enquanto segue um funcionário que tem autorização para entrar em ambientes controlados. O funcionário não sabe que alguém está o perseguindo. Por exemplo, um funcionário pode entrar no *lobby* da empresa usando um cartão de acesso na entrada trancada. Na sequência, esse funcionário abre a porta e a deixa fechar sozinha por uma mola automática, sem conferir se há alguém atrás dele. O atacante, então, se move silenciosamente para a porta enquanto ela está fechando e a segura para depois entrar.

Figura 11 - Acesso a ambientes controlados
Fonte: Shutterstock (2020)

A utilização não autorizada de um ambiente exige que alguns fatores não sejam eficazes, tais como:

- As portas não se fecharem rapidamente.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

- O funcionário seguido não prestar atenção em quem está por perto.
- Não haver um guarda atento ou outro pessoal esperando do outro lado da porta.

Há situações em que o alvo pode conhecer o atacante pessoalmente, ser cúmplice no ataque ou, ainda, pode ignorar o que o atacante está fazendo, isso é conhecido como *Piggybacking*. Por exemplo, se o invasor tiver sido dispensado recentemente pela empresa, um outro funcionário (alvo) pode não saber disso e assumir que é apenas mais um dia no escritório. No entanto, é mais provável que o alvo não conheça o invasor, mas apenas mantenha a porta aberta por educação ou cortesia.

Tailgating e *Piggybacking* também são exemplos de como você pode usar a engenharia social como parte de um ataque físico. Por exemplo, uma das maneiras mais fáceis para um invasor entrar em um prédio com acesso controlado seria entrar com os funcionários quando eles retornam após um alarme de incêndio.

FIAP

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

2 O AVANÇO TECNOLÓGICO NOS GOLPES DIGITAIS

O estudo dos golpes nos faz pensar quais são os próximos passos do outro lado da linha entre o lícito e o ilícito, se estamos jogando do lado “bom”, precisamos também conhecer o lado “ruim” para que possamos nos preparar para o próximo golpe.

Durante as explicações anteriores, foi apresentado para você diversos tipos possíveis de golpes que são utilizados hoje em dia, porém a combinação dessas técnicas é que torna realmente mais eficiente, aliada com a crescente tecnológica de imagem e de IA, podemos estar próximos de uma sociedade realmente em risco para golpes cada vez mais elaborados e precisos, com uma taxa de sucesso ainda maior.

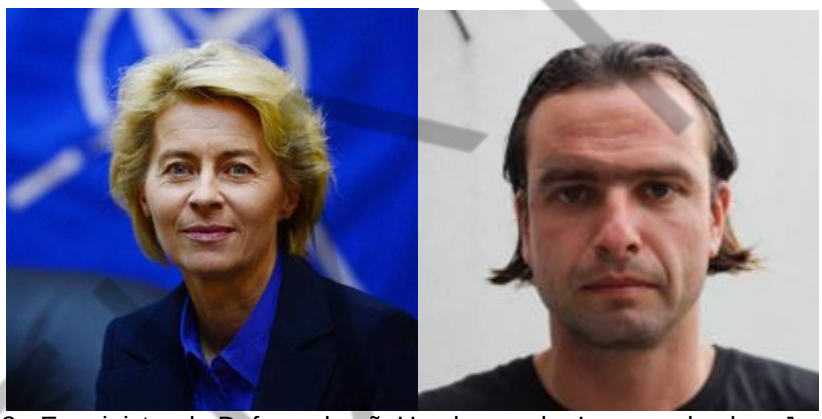


Figura 12 - Ex-ministra de Defesa alemã, Ursula von der Leyen, e hacker, Jan Krissler
Fonte: G1 (2014) e LinkedIn (2025)

Agora vamos analisar o trabalho do Jan Krissler em 2014, que utilizando apenas de uma foto conseguiu clonar a digital da ministra de Defesa alemã na época, Ursula von der Leyen.

Durante uma entrevista, a ministra foi fotografada em diversos ângulos por fotógrafos profissionais da mídia, essas fotos foram analisadas por Jan e processadas para que a digital da ministra fosse extraída com precisão.

Casos de estudo como esse provam que políticas empresariais de uso de dispositivos eletrônicos e fotos do ambiente de trabalho podem ser extremamente danosos para a companhia se forem vazados a criminosos, que podem se utilizar de informações como essas para prejudicar e extorquir a empresa.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

CONCLUSÃO

Ao ler todo esse conteúdo, sempre fica aquela sensação e vontade de perguntar: será que alguém é capaz de entrar em uma dessas?

É de se pensar, mas com certeza inúmeros casos acontecem diariamente e a habilidade que os engenheiros sociais têm de usar a inteligência linguística é algo surpreendente.

Fique atento e sempre oriente aqueles com menor conhecimento. Se você é gestor de uma empresa, foque sempre em treinamento aos colaboradores sobre os tipos de ataque social existentes e quais estão mais em alta para que minimamente a empresa esteja mais segura em relação a esses tipos de ataque.

FIAP

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

REFERÊNCIAS

CLULEY, Graham. **Coronavirus map used to spread malware**. 2020. Disponível em: <https://www.grahamcluley.com/coronavirus-map-used-to-spread-malware/>. Acesso em: 29 jan. 2025.

CYBER GURU ENTERPRISE. **Cyber Card #09 – Coronavirus**: un'epidemia di Malware. 2020. Disponível em: <https://cyberguru.it/2020/03/09/cyber-card-09-coronavirus-unepidemia-di-malware/>. Acesso em: 29 jan. 2025.

DEMARTINI, Felipe. **Golpistas estão usando SMS para roubar dados bancários.** 2017. Disponível em: <https://canaltech.com.br/seguranca/golpistas-estao-usando-sms-para-roubar-dados-bancarios-99702/>. Acesso em: 29 jan. 2025.

EVENTOSBH. **Cuidado com a fraude, não pague na dúvida**. [s.d]. Disponível em: <https://www.eventosbh.com.br/noticia/todas/cuidado-com-a-fraude-nao-pague-na-duvida/5/>. Acesso em: 29 jan. 2025.

GREENE, Thomas C. **Chapter One**: Kevin Mitnick's story. 2013. Disponível em: <https://www.theregister.co.uk/2003/01/13/chapter_one_kevin_mitnicks_story>. Acesso em: 29 jan. 2025.

KLEINMAN, Zoe. Hacker diz ter clonado digital de ministra alemã. **G1**, 29 dez. 2014. Disponível em: <https://g1.globo.com/tecnologia/noticia/2014/12/hacker-diz-ter-clonado-digital-de-ministra-alema.html>. Acesso em: 29 jan. 2025.

MITNICK, K.; SIMON, William L. **A arte de enganar**. São Paulo: Pearson, 2006.

MOUTON, F.; LEENEN, L.; VENTER, H. S. **Social Engineering Attack Examples, Templates and Scenarios**. 2016. Disponível em: <https://researchspace.csir.co.za/dspace/bitstream/handle/10204/9185/Mouton_2016.pdf?sequence=1&isAllowed=y>. Acesso em: 29 jan. 2025.

OFFENSIVE SECURITY. **MSFVENOM.** [s.d.]. Disponível em: <https://www.offsec.com/metasploit-unleashed/msfvenom/>. Acesso em: 29 jan. 2025.

REGISTRO.BR. **Boletos maliciosos**. [s.d.]. Disponível em: <https://registro.br/boletos-maliciosos/>. Acesso em: 29 jan. 2025.

ROHR, A. **Governo dos Estados Unidos alerta para fraudes cibernéticas envolvendo o coronavírus**. 2020. Disponível em: <https://g1.globo.com/economia/tecnologia/blog/altieres-rohr/post/2020/03/10/governo-dos-estados-unidos-alerta-para-fraudes-ciberneticas-envolvendo-o-coronavirus.ghtml>. Acesso em: 29 jan. 2025.

ROHR, A. **Saiba como funcionam os vírus que roubam senhas de banco.** 2009. Disponível em: <http://g1.globo.com/Noticias/Tecnologia/0,,MUL1320716-6174,00-SAIBA+COMO+FUNCIONAM+OS+VIRUS+QUE+ROUBAM+SENHAS+DE+BANCO.html>. Acesso em: 29 jan. 2025.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

SECURITY THROUGH EDUCATION. **The Social Engineering Framework**. Disponível em: <https://www.social-engineer.org/framework/se-tools/computer-based/social-engineer-toolkit-set/>. Acesso em: 29 jan. 2025.

SHIMOMURA, T.; MARKOFF, J. **Contra-ataque**: a história da captura do pirata cibernético mais procurado dos Estados Unidos. São Paulo: Companhia das Letras, 1996.

FIEBIG, Tobias; KRISSLER, Jan; HÄNSCH, Ronny. Security impact of high resolution smartphone cameras. In: **8th USENIX Workshop on Offensive Technologies (WOOT 14)**. 2014.

FALLIERE, Nicolas *et al.* W32. stuxnet dossier. **White paper, symantec corp., security response**, v. 5, n. 6, p. 29, 2011.

BAEZNER, Marie; ROBIN, Patrice. **Stuxnet**. ETH Zurich, 2017.

KUSHNER, David. The real story of stuxnet. **ieee Spectrum**, v. 50, n. 3, p. 48-53, 2013.

FIAP

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com